Informe de Hacking Ético

Actividad A08

Cliente: **INSECUR S.A.**

Estudiante: Ulises Wojcik
Username TryHackMe: wojcikulises
Branch: wojcik-ulises

Alcance y autorización

Este informe documenta exclusivamente actividades realizadas en laboratorios autorizados de TryHackMe. No se realizaron pruebas contra sistemas reales ni contra activos fuera del alcance académico de la actividad.

Índice

1. Resumen ejecutivo **3**

2. Datos generales **3**

3. Pre-pentesting **3**
3.1. Alcance . . . 3
3.2. Reglas de enfrentamiento . . . 3
3.3. Autorización . . . 4
3.4. Metodología . . . 4

4. Entorno y salas realizadas **4**

5. Actividades realizadas **4**
5.1. Reconocimiento y escaneo . . . 4
5.2. Enumeración . . . 4
5.3. Explotación controlada y post-explotación . . . 5

6. Hallazgos **5**
6.1. Ficha de hallazgo . . . 6

7. Resumen de severidades **8**

8. Recomendaciones **8**
8.1. Recomendaciones técnicas . . . 8
8.2. Recomendaciones administrativas . . . 9

9. Protocolo de contingencia **9**
9.1. Escenario de falla . . . 9
9.2. Plan de respuesta . . . 9

10. Anexos y evidencias **9**
10.1. Bitácora . . . 9
10.2. Capturas . . . 9
10.3. Hashes de flags y pruebas de finalización . . . 10
10.4. Declaración ética . . . 10

11. Fuentes **10**

1. Resumen ejecutivo

El presente informe documenta una práctica de hacking ético realizada sobre las salas **Pentesting Fundamentals**, **Basic Pentesting** y **Vulnversity** de TryHackMe. El trabajo siguió un enfoque progresivo: comprensión de la metodología, reconocimiento y enumeración, identificación de superficies de ataque, explotación controlada y documentación de evidencias.

La sala de elección para el Nivel 2 fue **Vulnversity**, orientada a la evaluación de servicios web y a la obtención de acceso en un entorno Linux de laboratorio.

En la práctica se trabajó sobre objetivos dinámicos asignados por TryHackMe. Los resultados principales fueron la identificación de servicios expuestos, el descubrimiento de recursos web y archivos de desarrollo, la obtención de acceso mediante una validación débil de cargas, el uso de credenciales débiles y la escalada de privilegios mediante configuraciones inseguras. No se incluyen credenciales ni flags en claro.

2. Datos generales

Campo	Valor
Cliente	INSECUR S.A.
Contratista	Ulises Wojcik
DNI	46399621
Username TryHackMe	wojcikulises
Email institucional	wojcikulises@uch.edu.ar
Sala de elección	Vulnversity
Salas obligatorias	Pentesting Fundamentals; Basic Pentesting
Branch de trabajo	wojcik-ulises
Fecha de inicio	.....
Fecha de cierre	.....

3. Pre-pentesting

3.1. Alcance

El alcance autorizado comprende exclusivamente las máquinas y actividades asignadas por TryHackMe dentro de las tres salas indicadas en este informe. Quedan excluidos los sistemas reales de INSECUR S.A., terceros, otros usuarios de TryHackMe y cualquier dirección IP que no haya sido asignada por la plataforma.

3.2. Reglas de enfrentamiento

- Realizar las pruebas únicamente sobre la IP asignada por TryHackMe.
- No ejecutar acciones de denegación de servicio, destrucción de datos o persistencia innecesaria.
- Usar fuerza bruta solo cuando la sala lo autorice y con límites razonables.
- Registrar comandos, resultados y evidencias durante cada fase.
- No publicar credenciales, tokens, claves privadas ni flags completas.

3.3. Autorización

La autorización se limita al entorno educativo de TryHackMe y a las salas indicadas. La actividad se realizó con finalidad académica, bajo condiciones controladas y dentro del alcance definido por la cátedra.

3.4. Metodología

Se utilizó una combinación de las fases presentadas en *Pentesting Fundamentals*, con referencias a PTES y NIST SP 800-115: pre-engagement, reconocimiento, escaneo, enumeración, explotación controlada, post-explotación, análisis de impacto y reporte.

4. Entorno y salas realizadas

Sala	Tipo	Objetivo
Pentesting Fundamentals	Obligatoria	Comprender las fases y el flujo profesional del pentesting.
Basic Pentesting	Obligatoria	Aplicar reconocimiento, enumeración, explotación y escalada en Linux.
Vulnversity	Elección	Evaluar una superficie web y practicar explotación controlada en Linux.

5. Actividades realizadas

5.1. Reconocimiento y escaneo

Se verificó la conectividad con la máquina asignada y se realizó el descubrimiento de puertos y servicios. Los resultados deben respaldarse con la bitácora y las capturas ubicadas en `evidencias/reconocimiento/` y `evidencias/escaneo/`.

Datos técnicos

Las máquinas de TryHackMe utilizan una IP dinámica que cambia en cada despliegue; por ese motivo no se consigna una IP fija en el informe. La comprobación se realizó con Nmap usando detección de servicios y, cuando correspondió, un escaneo completo de puertos.
En **Vulnversity** se identificaron servicios de red y un servidor web publicado en un puerto no estándar. En **Basic Pentesting** se identificaron servicios web, SSH y compartición de archivos SMB.
Los comandos y sus salidas deben conservarse en la bitácora del estudiante, sin credenciales ni secretos.

5.2. Enumeración

A partir de los servicios detectados se analizaron las superficies expuestas, especialmente los servicios web y los servicios de red indicados por cada sala. Se utilizaron únicamente herramientas y técnicas pertinentes al laboratorio.

Resultados de enumeración

En Vulnversity se descubrió el directorio `/internal/`, que contenía un formulario de carga de archivos.

En Basic Pentesting se enumeraron recursos SMB y el contenido web, incluyendo el directorio `/development/`. Allí se localizaron archivos de desarrollo que permitieron orientar la identificación de usuarios y credenciales.
La enumeración permitió priorizar la superficie web, SSH y SMB para las fases posteriores.

5.3. Explotación controlada y post-explotación

Las pruebas de explotación se limitaron a obtener el acceso previsto por las salas y demostrar el impacto de las vulnerabilidades. Una vez obtenido acceso, se verificó el contexto de ejecución sin realizar cambios permanentes fuera de lo necesario para resolver el laboratorio.

Resultado técnico

En Vulnversity se comprobó que el formulario de carga aplicaba una validación insuficiente de extensiones. Se utilizó una extensión PHP alternativa permitida por el servidor para ejecutar una reverse shell en el laboratorio. El acceso inicial correspondió al usuario que administra el servidor web. Posteriormente se localizó un binario SUID inseguro, `systemctl`, que permitió ejecutar una unidad controlada con privilegios de root.
En Basic Pentesting, la enumeración permitió identificar los usuarios `jan` y `kay`. Una contraseña débil permitió el acceso SSH inicial con el usuario de menor privilegio. Luego se obtuvo acceso a la cuenta de `kay` mediante una clave privada protegida con passphrase y, finalmente, se aprovechó una configuración de privilegios locales para alcanzar root.
La verificación se realizó con `whoami`, `uname -a`, revisión de permisos y `sudo -l`, cuando estuvo disponible.

6. Hallazgos

Los hallazgos se separan por defecto técnico para que cada causa tenga una remediación verificable.

ID	Componente	Descripción	Evidencia	Severidad
H-01	Basic Pentesting: directorio web	Listado de `/development` sin autenticación.	Gobuster y navegador	Medio
H-02	Basic Pentesting: notas internas	Archivos de desarrollo exponen información de usuarios y servicios.	Navegador: `dev.txt`, `j.txt`	Bajo
H-03	Basic Pentesting: SMB	Recurso compartido anónimo expone nombres internos.	`smbclient` sin credenciales	Medio
H-04	Basic Pentesting: SSH	Contraseña débil permite acceso remoto como `jan`.	Hydra y cliente SSH	Alto

H-05	Basic Pentesting: clave SSH	Clave privada legible y protegida con passphrase débil.	Permisos, ssh2john y John	Alto
H-06	Basic Pentesting: sudo	La cuenta `kay` dispone de privilegios sudo sin restricción.	`sudo -l` y shell root	Crítico
H-07	Vulnversity: carga web	El formulario permite subir y ejecutar un archivo `.phtml`.	Gobuster, formulario y netcat	Crítico
H-08	Vulnversity: SUID	`systemctl` con SUID permite ejecutar acciones como root.	`find` y systemctl	Crítico

6.1. Ficha de hallazgo

H-01 — Listado de directorios

Fase: Escaneo
Descripción: `/development` lista su contenido sin autenticación.
Componente afectado: Servidor web de Basic Pentesting.
Categoría OWASP/CWE: A05:2021 Security Misconfiguration; CWE-548.
CVE: No aplica.
CVSS estimado: Medio.
Impacto en CIA: Confidencialidad.
Salvaguarda propuesta: Deshabilitar el listado de directorios y restringir el acceso a contenido interno.
Riesgo residual: Bajo.

H-02 — Notas internas expuestas

Fase: Reconocimiento
Descripción: `dev.txt` y `j.txt` exponen información sobre usuarios, servicios y credenciales.
Componente afectado: Contenido estático del servidor web.
Categoría OWASP/CWE: A01:2021 Broken Access Control; CWE-200.
CVE: No aplica.
CVSS estimado: Bajo.
Impacto en CIA: Confidencialidad.
Salvaguarda propuesta: Retirar notas de desarrollo del webroot y separar documentación interna del contenido público.
Riesgo residual: Bajo.

H-03 — Share SMB anónimo

Fase: Escaneo y enumeración
Descripción: Un recurso SMB accesible sin credenciales expone nombres internos.
Componente afectado: Servicio Samba.

Categoría OWASP/CWE: A05:2021 Security Misconfiguration; CWE-284.
CVE: No aplica.
CVSS estimado: Medio.
Impacto en CIA: Confidencialidad.
Salvaguarda propuesta: Deshabilitar el acceso guest y exigir autenticación en cada recurso compartido.
Riesgo residual: Bajo.

H-04 — Contraseña SSH débil

Fase: Explotación
Descripción: La contraseña de `jan` es susceptible de encontrarse en una lista pública y permite acceso SSH.
Componente afectado: Servicio SSH y política de autenticación.
Categoría OWASP/CWE: A07:2021 Identification and Authentication Failures; CWE-521.
CVE: No aplica.
CVSS estimado: Alto.
Impacto en CIA: Confidencialidad e integridad.
Salvaguarda propuesta: Aplicar contraseñas robustas, MFA, limitación de intentos y bloqueo ante fuerza bruta.
Riesgo residual: Bajo.

H-05 — Clave privada SSH legible

Fase: Post-explotación
Descripción: La clave privada de `kay` es legible por otros usuarios y su passphrase es débil.
Componente afectado: Archivos de credenciales del usuario.
Categoría OWASP/CWE: A01:2021 Broken Access Control; CWE-732.
CVSS estimado: Alto.
Impacto en CIA: Confidencialidad e integridad.
Salvaguarda propuesta: Usar permisos 600, directorios `.ssh` restrictivos, passphrases robustas y rotación de claves.
Riesgo residual: Bajo.

H-06 — Sudo sin restricción

Fase: Post-explotación
Descripción: `kay` puede ejecutar comandos como root mediante una regla sudo demasiado amplia.
Componente afectado: Configuración sudoers de Basic Pentesting.
Categoría OWASP/CWE: A01:2021 Broken Access Control; CWE-269.
CVSS estimado: Crítico.
Impacto en CIA: Confidencialidad, integridad y disponibilidad.
Salvaguarda propuesta: Aplicar mínimo privilegio y autorizar solo comandos administrativos concretos.
Riesgo residual: Bajo.

H-07 — Subida de archivos ejecutables

Fase: Explotación
Descripción: El formulario de Vulnversity permite cargar un archivo `.phtml`, almacenarlo dentro

del webroot y ejecutarlo como `www-data`.
Componente afectado: Aplicación web en el puerto 3333.
Categoría OWASP/CWE: A05:2021 Security Misconfiguration; CWE-434.
CVSS estimado: Crítico.
Impacto en CIA: Confidencialidad, integridad y disponibilidad.
Salvaguarda propuesta: Validar contenido en servidor, usar lista blanca, almacenar fuera del webroot y deshabilitar scripts en uploads.
Riesgo residual: Bajo.

H-08 — systemctl con SUID

Fase: Post-explotación
Descripción: `systemctl` posee SUID y permite ejecutar una unidad controlada con privilegios de root.
Componente afectado: Permisos del sistema Linux de Vulnversity.
Categoría OWASP/CWE: A01:2021 Broken Access Control; CWE-269.
CVSS estimado: Crítico.
Impacto en CIA: Confidencialidad, integridad y disponibilidad.
Salvaguarda propuesta: Quitar el bit SUID, auditar binarios privilegiados e impedir que el usuario web escriba unidades de systemd.
Riesgo residual: Bajo.

7. Resumen de severidades

Severidad	Cantidad	IDs
Crítico	3	H-06, H-07, H-08
Alto	2	H-04, H-05
Medio	2	H-01, H-03
Bajo	1	H-02
Total	8	H-01 a H-08

8. Recomendaciones

8.1. Recomendaciones técnicas

1. Mantener actualizados el sistema operativo, los servicios expuestos y las aplicaciones web.
2. Deshabilitar servicios innecesarios y restringir la exposición de puertos mediante reglas de firewall.
3. Aplicar validación estricta de archivos subidos y permitir únicamente extensiones y contenidos esperados.
4. Utilizar cuentas con mínimo privilegio y revisar permisos de archivos, binarios SUID y reglas de sudo.
5. Separar los entornos de laboratorio, desarrollo y producción.
6. Centralizar registros y monitorear intentos de acceso anómalos.

8.2. Recomendaciones administrativas

- Formalizar reglas de enfrentamiento y autorizaciones antes de cada evaluación.
- Establecer revisiones periódicas de vulnerabilidades y remediaciones.
- Capacitar al personal en gestión de credenciales, actualización de sistemas y respuesta a incidentes.
- Mantener inventarios actualizados de activos, responsables y criticidad.

9. Protocolo de contingencia

9.1. Escenario de falla

Una prueba de enumeración o explotación podría generar indisponibilidad temporal del servicio evaluado, especialmente si se ejecutan solicitudes excesivas o una configuración vulnerable reacciona de forma inesperada.

9.2. Plan de respuesta

1. **Activación:** detectar la interrupción mediante monitoreo, respuesta HTTP, conexión de red o aviso del responsable.
2. **Contención:** detener inmediatamente la herramienta, conservar la evidencia y evitar nuevos cambios sobre el objetivo.
3. **Recuperación:** aplicar rollback, restaurar snapshot o backup y validar nuevamente la disponibilidad.
4. **Comunicación:** informar al docente y al responsable designado del laboratorio.
5. **Post-mortem:** documentar la causa, el impacto, las acciones tomadas y las medidas preventivas.

RTO y RPO

RTO estimado: 4 horas
RPO estimado: 1 hora

10. Anexos y evidencias

10.1. Bitácora

La bitácora de comandos debe incorporarse en `bitacora/`, eliminando previamente contraseñas, tokens, claves privadas y datos personales.

10.2. Capturas

Las evidencias deben organizarse por fase:

- `evidencias/reconocimiento/`
- `evidencias/escaneo/`
- `evidencias/explotacion/`
- `evidencias/post/`

Actualmente se dispone de una captura de finalización de una sala en `evidencias/reconocimiento/pentesti`
Debe complementarse con capturas donde sean visibles el username, la IP objetivo, la fecha y la evidencia técnica correspondiente.

10.3. Hashes de flags y pruebas de finalización

No se incluyen flags en claro. Los hashes corresponden a las pruebas solicitadas por las salas, no a los IDs de hallazgos H-01 a H-08.

Prueba	SHA-256
F-01 — Pentesting Fundamentals, finalización de la sala	583f30ba446f9f74d509726d25956b4b75ad965f953feffc996f6ad1382dc8d6
F-02 — Basic Pentesting, contenido de `pass.bak`	3ffd53ec80858f9ddcd75d69102724ab1bc1020855fff924227f618c4bfccf57
F-03 — Vulnversity, `/home/bill/user.txt`	d324bd433001e5bdfe39e04d794539c15b51982a5bf6fc78efea46369b7bf956
F-04 — Vulnversity, `/root/root.txt`	cfbc740435ad60030304080e35131ffcaf8ac5f71b65e002f5b546aa3cda7ce8

10.4. Declaración ética

Declaro que todas las actividades documentadas se realizaron dentro del alcance autorizado, en entornos controlados de TryHackMe y con fines exclusivamente académicos.

Ulises Wojcik ....
Nombre y apellido Fecha

11. Fuentes

- TryHackMe, *Pentesting Fundamentals*: https://tryhackme.com/room/pentestingfundamentals
- TryHackMe, *Basic Pentesting*: https://tryhackme.com/room/basicpentestingjt
- TryHackMe, *Vulnversity*: https://tryhackme.com/room/vulnversity
- OWASP Foundation, *Web Security Testing Guide*: https://owasp.org/www-project-web-security-testin
- NIST, *SP 800-115: Technical Guide to Information Security Testing and Assessment.*